PARTICIPANT PACKET

AI-Assisted Cyber Operations and Authorized Testing

Session 4 of AI + Cyber: AI Powered Cybersecurity

Date	Friday, November 13, 2026
Time	1:30 to 5:30 p.m. ET, online
Facilitator	Frazier A. Smith, Ed.D., Central Piedmont Community College
Labs	Lab 7: Authorized Assessment of the Staging Portal Lab 8: Redesign a Legacy Lab as Purple Team

Nobody scans anything today. Northbridge Technical College, its staging network, and its people are fictional, and every hostname ends in `.example`. The Northbridge IT Security Office recorded the Lab 7 captures inside the authorized window from its assessment workstation. Today's lab is about interpretation, scope, and evidence, not about running scanners. The captures and telemetry are Confidential in the story, so they stay on the campus AI server. The only real-world material you use today is the public NVD and CISA KEV record for CVE-2021-41773.

This material is based upon work supported by the U.S. National Science Foundation under Grant No. 2300188. Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the National Science Foundation.

SESSION 4

Session at a Glance

Session 3 asked whether an analyst can trust a model's account of a threat. Today asks whether an assessor can trust a model's account of a target, and where a human approval has to sit once the model can act as well as advise. Northbridge is about to pilot an AI-enabled student-support portal, and suspicious requests have appeared on the staging network that hosts it. Your team holds a written authorization for a limited assessment of two staging hosts. You read back the scope, record raw output, ask a model for ranked hypotheses, validate its claims, request approval for one consequential test, and brief a go or no-go recommendation. In Lab 8 you redesign the scanning or penetration-testing lab you brought as a purple-team lab.

Time (ET)	Segment	You leave with
1:30 to 1:45	Opening: Northbridge since November 6, the go or no-go question, your first estimate, scope read-back	A signed scope read-back
1:45 to 2:05	Block 1: Evidence Before Interpretation, with Demo 1 and Demo 2	Where the approval gate sits
2:05 to 2:55	Lab 7 Part A: inventory, hypotheses, validation, approval request	Observation log, hypothesis record, approval request
2:55 to 3:05	Break. The facilitator releases new files	
3:05 to 4:00	Lab 7 Part B: Demo 3 (3:05), team work (3:20), Demo 4 (3:47), finish (3:55)	Timeline, finding write-up, detection and remediation
4:00 to 4:25	Briefings, three minutes per team, then the reveal	A go or no-go recommendation
4:25 to 5:10	Lab 8: Redesign a Legacy Lab as Purple Team	A purple-team lab canvas
5:10 to 5:30	Debrief, second estimate, exit ticket, Session 5 preview	Exit ticket

By 5:30 You Will Be Able To

1. Restate a written authorization in all seven elements and the approval rule, and classify a proposed action, including one a model recommends, as in scope, out of scope, or requiring approval.
2. Record raw tool output with tool, command, target, and time zone before any model interpretation, and keep observed facts separate from inferred ones.
3. Use a model to generate ranked hypotheses from scan, HTTP, and log output, and validate a service, version, or vulnerability claim with at least two independent pieces of evidence.
4. Write a four-part approval request for a consequential test that names the least invasive method, and reconcile a conflicting alert by checking clocks, time zones, sensor placement, and false-positive alternatives.
5. Translate one offensive finding into a detection idea, a remediation with an owner, a validation step that repeats the original observation, and a confidence statement, and redesign a legacy lab to require the same chain.

What You Need

You need a browser with a terminal tab and an Open WebUI tab on the range, the Lab Manual, and your copy of the Session 4 Assessment Workbook. Bring your Evidence Log, your Legacy Lab Inventory sheet from prework, the handout, deliverable, and rubric of the lab you will redesign with student names removed, and the raw output sample you saved in prework.

Nobody Scans Today

Live targets on the lab server were not approved for this session. The Northbridge IT Security Office recorded every capture inside the authorized window from its assessment workstation, `sec-scan01`. The captures are real `nmap` and `curl` output from staging services run for this purpose. You read them, you do not reproduce them. Do not run `nmap`, `curl`, or any other network command against any address.

> **Takeaway artifacts:** a scope read-back, an observation log, a hypothesis record, an approval request, a timeline reconciliation, a finding write-up with detection and remediation, a purple-team lab canvas, and Evidence Log rows.

OPENING · 1:30

Northbridge Since November 6

Date	What happened
Nov 6	Lab 5: Kwame Mensah's analysts briefed the provost on the GLASSFERN reporting.
Nov 9	A staging deployment of the student-support portal, build 2026.11.2, goes out at 11:42 a.m. ET.
Nov 10	From 9:01 to 9:04 p.m. ET, a client on the campus VPN sends requests to the staging portal and the staging API. The staging network sensor records them. Nobody reads the records until morning.
Nov 11	The portal developers notice odd entries in the staging access log and forward them to the IT Security Office. That afternoon a network engineer sweeps the whole staging subnet with `nmap` from his workstation without authorization.
Nov 12	Provost Dr. Alicia Harmon and Chief Information Officer Dr. Samuel Okonjo ask for a go or no-go recommendation on the December 1 pilot by Monday, November 16. Information Security Officer Kwame Mensah signs a limited authorization for today, 2:00 to 4:00 p.m. ET.
Today	You are his assessment team. The security office's operator, Marcus Bell, recorded the authorized captures. The one consequential test waits for Mensah's written approval.

The Decision

> Should the AI-enabled student-support portal start its December 1 pilot as planned, start it only after named conditions are met, or wait?

Choice	What it costs
Delay the pilot	First-year students in two programs lose an AI assistant for financial aid, advising, and tutoring questions before spring registration. The vendor prices the pilot by start date.
Go ahead	The staging environment becomes production. If it exposes configuration, or if an unexplained visitor already has something from it, the exposure goes live with the pilot.

Your recommendation must separate what the captures show from what a banner, a scanner, an alert, or a model claims.

Your Estimate

Before you see any output: how likely is it that the staging portal has a vulnerability serious enough to delay the pilot? Mark one ICD 203 term now and the same question again after the briefings [8].

	Almost no chance	Very unlikely	Unlikely	Roughly even chance	Likely	Very likely	Almost certain
Before any output	☐	☐	☐	☐	☐	☐	☐
After the briefings	☐	☐	☐	☐	☐	☐	☐

What moved your estimate, or why it did not move:

Rules of Engagement

The full text of the document that governs Lab 7. The authorization memo, `authorization_mensah_2026-11-12.md`, carries the same terms in memo form with Kwame Mensah's signature block. Where the two differ, the rules of engagement govern.

Northbridge Technical College, IT Security Office

Issued Thursday, November 12, 2026, by Kwame Mensah, Information Security Officer. Distribution: the assessment team; Dr. Samuel Okonjo, Chief Information Officer.

1. Target. Two hosts on the staging network, and only the services named here:

- `portal-stg.northbridge-tc.example`, 10.40.13.10, TCP 80 (the student-support portal front end).
- `api-stg.northbridge-tc.example`, 10.40.13.11, TCP 8080 (the student-support portal API).

No other host, address, port, or name is authorized. The staging gateway 10.40.13.1, the HR database replica `hrdb-replica.northbridge-tc.example` at 10.40.13.20, every other address in 10.40.13.0/24, and every address outside Northbridge are out of scope. The only authorized source of test traffic is the security office assessment workstation `sec-scan01`, 10.40.13.50, operated by the security office.

2. Time window. Friday, November 13, 2026, from 2:00 p.m. to 4:00 p.m. Eastern Time (19:00 to 21:00 UTC). Nothing runs before or after the window. A capture taken outside the window is not evidence for this assessment.

3. Allowed techniques.

- Name resolution of the two target names.
- TCP connect service enumeration of the two targets (`nmap -sT -sV`), run by the operator from `sec-scan01`.
- Read-only HTTP `HEAD` and `GET` requests to `/`, `/robots.txt`, `/healthz`, `/version`, and to one path that does not exist, to observe error behavior.
- Review of the staging package inventory and the staging sensor telemetry that the security office provides.
- Analysis of captures and telemetry with the campus AI server (models on the lab server only).

4. Prohibited actions.

- Any activity against an address, host, port, or name not listed in element 1, including every public address.
- SYN, UDP, or operating system detection scans (`-sS`, `-sU`, `-O`), Nmap scripts in the `vuln`, `exploit`, `brute`, `intrusive`, or `dos` categories, and any exploit framework module.
- Path-traversal, injection, or other attack payloads; password guessing; load or denial-of-service testing.
- Downloading or opening any file found in a directory listing.
- Use of any credential.
- Pasting captures, telemetry, or findings into any hosted AI service.

5. Data rules. The captures, the telemetry, and the package inventory are Confidential under the interim AI data use policy. They stay on the lab server and the campus AI server. Describe any exposed file by name, size, and timestamp only, and never copy its contents into notes, the workbook, or a prompt. Keep working copies in your range home directory.

6. Approval required. Any request beyond the paths listed in element 3, any request that may expose information the data rules restrict (configuration files, backup or archive paths, directory listings), and any test that could change data or service state requires written approval from Kwame Mensah before it runs. A request states the finding so far with a pointer to the raw output, the proposed test and its expected effect, a less invasive alternative, and how the target returns to its prior state. A model's recommendation is never approval.

7. Stop conditions. Stop at once, preserve your record, and notify Kwame Mensah if any of these occur: a result or a proposed step points outside the two targets (an address, hostname, port, or service not in element 1); a target slows, errors repeatedly, or stops responding; data appears to be real (a real person's name or record, a working credential); a tool or a model begins or proposes an action outside this document.

Immediate notification without stopping. If any evidence shows that a third party has already accessed restricted data, notify Kwame Mensah at once and continue only within this scope.

8. Reporting path. Stop conditions and immediate notifications go to Kwame Mensah in the session chat as they happen. Each team delivers a written finding to Kwame Mensah by 4:25 p.m. today: the finding, its raw-output evidence, a detection idea, a remediation with an owner, a validation step, a confidence statement, and a go or no-go recommendation for the December 1 pilot. Mensah briefs the provost and the CIO. Nobody else receives findings.

The facilitator plays Kwame Mensah in the session chat for approvals, stop conditions, and notifications.

OPENING · 1:38 · TEMPLATES/SCOPE_READBACK.MD

Scope Read-Back

Open only `rules_of_engagement.md` and this template. One member reads the scope aloud. The team writes one sentence per element in its own words, classifies the six proposed actions, and signs with names and the time. Post the read-back in the shared folder by 1:45. Nobody opens `captures/` until the facilitator says so. The read-back is the first scored act of Lab 7.

Element	Our sentence
Target	
Time window	
Allowed techniques	
Prohibited actions	
Data rules	
Approval required	
Stop conditions	
Reporting path	

Six Proposed Actions

Verdict: in scope, out of scope, or requires approval. The deciding element is the element of the rules of engagement that settles the verdict.

#	Action	Verdict	Deciding element
1	Review the operator's `nmap -sT -sV` capture of 10.40.13.11 taken at 2:04 p.m.		
2	Ask the campus AI server to rank hypotheses about the API banner		
3	Paste the portal access log into a hosted chatbot to get a second opinion		
4	Use the `nmap` results for 10.40.13.20 from the November 11 sweep to describe the subnet		
5	Request `http://portal-stg.northbridge-tc.example/backup/`		
6	Send a traversal request to the API to see whether the banner is true		

Name	Role	Time (ET)

BLOCK 1 · 1:45 · REFERENCE

Evidence Before Interpretation

The Raw-Output Record

Record every capture before anyone asks a model about it. A record that a reader can check names six things.

Field	What it holds
Tool and version	As the capture header and the tool's own output state them
Command	The exact command, copied, never retyped from memory
Target as authorized	The host, address, and port as element 1 of the rules of engagement writes them
Start time and zone	The time with its zone as written in the file. Convert later, in a separate column
File and SHA-256	The file name and its hash, so a reader can confirm the file is the one you read
Observed	Only what the tool printed. No interpretation and no model output

Observed Versus Inferred

Observed: the tool printed it	Inferred: a person or a model concluded it
The scan line names a product and a version for an open port	The host runs that product at that version
A response carried a `Server` header with a value	The server software is the one the header names
A model's answer names a CVE for the service	The service is vulnerable to that CVE

Version detection compares a service's responses with stored match patterns, and the Nmap Reference Guide notes that most services do not provide all the information it looks for [3]. NIST SP 800-115 adds that an administrator can alter the transmitted banners [1]. A banner is a claim the service makes about itself.

The Four-Part Hypothesis Request

1. The raw output, pasted whole, with tool, command, target, and time.
2. The scope: the rules of engagement, so that every proposed step is checked against them.
3. Two to four hypotheses that explain the output, most likely first.
4. For each hypothesis, the evidence that would confirm it, the evidence that would rule it out, and the least invasive next step inside the scope.

`bin/hypothesize.sh` sends this request for you. A model's hypothesis is a proposal. A model's recommendation is never approval.

Consequential Tests and the Approval Gate

Consequential test	A test whose effects reach beyond reading: it changes data, can disrupt a service, uses a credential, or exposes information the data rules restrict.
Approval gate	The point where a consequential test waits until a named person who owns the risk says yes in writing.
Least invasive method	The test that demonstrates the finding with the smallest effect on the target and on restricted data.
Purple-team translation	One observation turned into a detection idea, a remediation with an owner, a validation step that repeats the original observation, and a confidence statement.

Demo 1 and Demo 2 Notes

Demo 1 Notes: Raw Output, Then Hypotheses

A sentence in the first answer the log did not support	
A sentence in the second answer the log did not support	

Demo 2: GTG-1002 and Where the Humans Sat

In mid-September 2025 Anthropic detected an espionage campaign it attributes with high confidence to a Chinese state-sponsored group it designates GTG-1002 [12, 13]. The operators built a framework around Claude Code and Model Context Protocol (MCP) servers that drove commodity tools: network scanners, database exploitation frameworks, password crackers, and binary analysis suites [13]. They obtained its cooperation through role-play, claiming to be employees of a legitimate security firm, and by splitting the attack into small tasks that each looked legitimate [13].

What the report states	Detail
Targets and outcome	Roughly 30 entities. Anthropic's investigation validated a handful of successful intrusions.
Division of labor	The AI executed an estimated 80 to 90 percent of tactical work. Human effort was an estimated 10 to 20 percent.
Where the humans sat	Approving the move from reconnaissance to active exploitation, authorizing use of harvested credentials for lateral movement, and deciding the scope of data exfiltration.
Over-claiming	Claude "frequently overstated findings and occasionally fabricated data," claiming credentials that did not work and discoveries that were publicly available. Every claimed result needed validation.

Which of today's rules of engagement elements matches each human decision point	
What separates the GTG-1002 gates from the gates in Lab 7	

Class Line: Where Should the Gate Sit in an Agentic Workflow?

The Lethal Trifecta and the Agentic Top 10

Simon Willison names three capabilities that together let an attacker turn an agent against its user: access to private data, exposure to untrusted content, and the ability to externally communicate [9]. The cause is that models follow instructions found in content, wherever the content came from. His advice for anyone combining tools is to avoid the combination entirely [9].

The OWASP Top 10 for Agentic Applications, released December 9, 2025, lists ten risks, ASI01 to ASI10 [10]. Two matter most today. ASI01, Agent Goal Hijack, is an attacker redirecting an agent's objectives through content the agent reads, because agents cannot reliably distinguish instructions from related content. ASI02, Tool Misuse and Exploitation, is an agent applying a legitimate tool in an unsafe or unintended way. Its mitigations include requiring human approval for high-impact actions [11].

LAB 7 · 2:05 TO 4:00 · TEAMS OF THREE

Lab 7: Authorized Assessment of the Staging Portal

Your team is Kwame Mensah's assessment team. The commands are in the Lab Manual. This packet holds the forms. Decide for every file whether the rules of engagement let you use it. If a result or a proposed step points outside the two targets, stop that line of work, save your shell history with `history > ~/lab7/stop_record.txt`, and post the stop to Kwame Mensah.

Team Roles, Rotated at the Break

Role	Job	Part A	Part B
Operator of record	Runs every command on the range and keeps the observation log		
Analyst	Runs `hypothesize.sh` and keeps the hypothesis record		
Scope officer	Checks every proposed step against the rules of engagement, owns the approval request, and calls any stop condition		

What Is in the Lab 7 Folder

Path	What it is
`authorization_mensah_2026-11-12.md`, `rules_of_engagement.md`	The authorization and its rules of engagement
`pilot_decision_request.md`	The provost's and CIO's request for a go or no-go by November 16
`staging_network_note.md`	The network team's description of the staging subnet, its sensor, and its gateway
`captures/C00_network_team_sweep_2026-11-11.txt`	Network team sweep, November 11
`captures/C01` to `C06`	The security office's captures: name resolution, `nmap -sT -sV` of each target, HTTP responses from each target, and the staging package inventory
`telemetry/`	The staging sensor's Zeek `conn.log` and `http.log`, Suricata `eve.json`, and the portal's nginx access log, with a README
`injects/`	Empty at the start. Items appear during the session
`bin/hypothesize.sh`	Sends the captures you name, plus the rules of engagement, to the campus model with the four-part hypothesis request
`templates/`	Every form in this packet as a Markdown file, plus the CVE-2021-41773 reference

Part A Steps, 2:05 to 2:55

Time	Step
2:05 to 2:13	**1. Inventory.** Read the network note and the captures. List each in-scope host, its port, and the service the tool reported. Classify every capture against the scope.
2:13 to 2:20	**2. Raw-output record.** One observation-log row per capture, with its hash, before any model run.
2:20 to 2:30	**3. Ranked hypotheses.** Run `hypothesize.sh` on each scan. Record every hypothesis with the model and time, and mark every proposed step against the scope.
2:30 to 2:40	**4. Validate service identity.** Before you accept any service, version, or vulnerability claim, find at least two pieces of evidence that the claim itself did not supply.
by 2:45	**5. Approval request.** The scope officer posts the four-part request to Kwame Mensah in the chat and records the reply.
2:45 to 2:55	**6. Start the timeline.** List the November 10 and 11 events from the telemetry with the source address, sensor, and file. Keep each time as the file records it.

LAB 7 · PART A, STEP 2 · TEMPLATES/OBSERVATION_LOG.MD

Observation Log

The operator of record writes one row per capture or telemetry file before anyone asks a model about it. The Observed column holds only what the tool printed. An inference goes in the hypothesis record. The first row is a worked example from `C01`.

Row	Capture or file	SHA-256 (first 8)	Tool and version	Command	Target as authorized	Start time and zone	Observed (what the tool printed)	Excluded? and why
1	*`C01_name_resolution.txt`*	*From `sha256sum`*	*getent (Alpine Linux, musl)*	*`getent hosts portal-stg.northbridge-tc.example api-stg.northbridge-tc.example`*	*The two target names in element 1*	*2026-11-13 14:02:10 EST (19:02:10 UTC)*	*Two lines: 10.40.13.10 portal-stg, 10.40.13.11 api-stg*	*No*

Hash every capture with `sha256sum captures/*.txt` and read the header lines with `grep '^# ' captures/C03_*`, one capture ID at a time.

Hypothesis Record

The analyst writes one row per hypothesis, from the model or from the team. Record the model and the time from the `hypothesize.sh` header. The scope officer marks every proposed next step in scope, out of scope, or requires approval, with the deciding element, before anyone acts on it. Never delete a row. Correct it.

#	Hypothesis	Source (model and time, or team)	Evidence to confirm	Evidence to rule out	Proposed next step	Scope verdict	Result	Correction
1								
2								
3								
4								
5								
6								
7								
8								

Validation: Evidence the Claim Did Not Supply

Host and claim	Evidence 1, with file and line	Evidence 2, with file and line	Verdict and confidence

Two items count as two pieces of evidence only when each rests on its own observation.

LAB 7 · PART A, STEP 5 · DUE 2:45 · TEMPLATES/APPROVAL_REQUEST.MD

Approval Request

Any request beyond the paths in element 3, any request that may expose restricted information, and any test that could change data or service state waits for written approval from Kwame Mensah. The scope officer posts the request in the session chat. A request missing any part is returned with the missing part named. A model's recommendation is never approval.

Worked Example From the Prework: Fernwood County Library District

1. Finding so far and raw-output pointer	The test site's search returned HTTP 500 for a query containing an apostrophe, in the district's log export at 19:02:30, line 2. The same search without the apostrophe returned 200.
2. Proposed test and expected effect	Submit one form value from the tester's workstation that would create one record in the test database, to confirm an input-handling flaw. Expected effect: one new synthetic record.
3. Less invasive alternative	Repeat the read-only apostrophe search once and read the error page. It shows the error, but it does not show whether the input reaches the database, so it is not sufficient to confirm the flaw.
4. Return to prior state	Delete the record by its ID and confirm the record count matches the count before the test.

Your Request

1. Finding so far, with the capture ID and line	
2. Proposed test: the exact request, the source, the target, and what it changes	
3. Less invasive alternative, and why it is or is not sufficient	
4. How the target returns to its prior state	
Requested by, role, and time (ET)	
Approver response (approved, returned, denied), its text, and time	

LAB 7 · PART B · 2:55 TO 4:00

Part B and the Releases

Break and Releases, 2:55 to 3:05

Teams whose approval request was approved find the approved result in `/opt/nitic/session4/lab7/captures/`. A team without an approved request posts a complete request first. Every team finds two new items in `/opt/nitic/session4/lab7/injects/`. The facilitator posts in chat when the files are in place. Read both before you change anything.

Demo 3: Live SOC, AI Triage With an Approval Gate, 3:05 to 3:20

A facilitator demo on a separate lab system. Watch it and run no commands.

What the evidence check caught	

Team Work, 3:20 to 3:47

Time	Step
3:20 to 3:24	**1. Read the two new items.** For each, write what it claims, what evidence the claim rests on, and whether that evidence is independent of what your team already has.
3:24 to 3:28	**2. Revise the hypotheses.** Re-score each hypothesis. Record every change in the Correction column with the time and the reason.
3:28 to 3:30	**3. Refuse or escalate.** Check every action a model or a new item recommends against the rules of engagement. If an action is outside the scope, do not take it. Post an escalation to Kwame Mensah: what was recommended, the element that puts it outside the scope, and what your team did instead.
3:30 to 3:38	**4. Reconcile the timeline.** Put every record on one UTC timeline and work the four checks.
3:38 to 3:42	**5. Correlate the approved result with the telemetry.** Note every request to the same path: time, status, size, and whether a sensor alerted. If any evidence shows that a third party already accessed restricted data, notify Kwame Mensah at once and continue within the scope.
3:42 to 3:47	**6. Draft the detection idea.** Data source, condition, expected false positives. Write it before Demo 4.

Demo 4: From Finding to Detection, 3:47 to 3:55

A facilitator demo on the same lab system. Write your detection idea before it starts.

Which of your negative cases the rule missed	

Finish, 3:55 to 4:00

7. Translate the finding. Revise the detection idea against Demo 4. Write the remediation with its owner, the validation step, the confidence statement, and the recommendation. Add Evidence Log rows for every model run. The written finding goes to Kwame Mensah by 4:25.

Timeline Reconciliation

Copy each time and source address exactly as the file records it. Fill Corrected UTC and Client after reconciliation only after the four checks, and note which check explains each correction.

Event	Source file and sensor	Time as recorded	Zone	Corrected UTC	Source address as recorded	Client after reconciliation	Notes

Check 1: Time zone. Which zone each source reports in, and how you know	
Check 2: Clock. Whether two records of the same request show the same time, and which clock you trust	
Check 3: Sensor placement. Where each sensor sits, and which source address it can see	
Check 4: False-positive alternative. What the alert matched, how the target responded, and whether the evidence supports the alert's assessment	

Finding Write-Up and Detection and Remediation

One write-up per finding. Describe any exposed file by name, size, and timestamp only.

Title	
Host and service	
Evidence: capture pointers	
Telemetry correlation	
Severity and why	
Confidence statement: each part of the finding, and what would change it	
Recommendation for December 1: go, conditional go with named conditions and owners, or no-go	

Detection Idea

Data source	Condition	Expected false positives

Remediation

Owner	Change

Validation Step

Repeat of the original observation	Expected new result

LAB 7 · BRIEFINGS · 4:00

Briefing Format and Evidence Log Rows

One member briefs the whole room in this order and stops at three minutes.

Part	What it covers
1. Scope, 30 seconds	What the team was authorized to do, and one thing it refused or escalated, with the deciding element
2. Evidence, 60 seconds	The one finding with its capture pointer and the telemetry correlation. The verdict on the API banner with the two strongest pieces of evidence
3. Remediation, 60 seconds	The detection idea, the remediation and its owner, the validation step, and the confidence
4. Recommendation, 30 seconds	Go, conditional go with named conditions, or no-go for December 1

Our recommendation, in one sentence	
The condition that would change it	

Evidence Log Rows

Add one row for every `hypothesize.sh` run and every other model output your team used.

Row	Prompt	Highest data tier	Validation method	Verdict
Each `hypothesize.sh` run	The question and the files in context, as the script printed them	Confidential	The captures and telemetry that confirmed or ruled out each hypothesis	Accept, revise, or reject, with the correction

Entry ID	Date and time	Tool and model	Prompt	Validation method	Verdict	Correction

LAB 8 · 4:25 TO 5:10 · INDIVIDUAL AND PAIRS

Lab 8: Redesign a Legacy Lab as Purple Team

Redesign the scanning or penetration-testing lab you brought. Start from your Legacy Lab Inventory: copy each inventory field into the matching canvas field, then change it. The canvas is `/opt/nitic/session4/lab8/purple_team_lab_canvas.md`. A filled example built from the prework's sample Network Discovery Lab appears at 4:25, because it uses the Lab 7 answers as patterns.

Canvas field	Your draft
1. Learner and prerequisite	
2. Observable performance	
3. Scenario decision	
4. Authorized assets and stop conditions	
5. AI role and permissions	
6. Expected failure or misconception	
7. Independent validation	
8. Student evidence	
9. Instructor truth and hints	
10. Reset and fallback	
11. Accessibility path	
12. Workforce alignment	

The Redesign Must Include

- [ ] **Authorization.** A rules-of-engagement document with all seven elements and the approval rule, and a scope read-back as the first scored act.
- [ ] **Known expected findings.** The instructor's truth for every target, with at least one planted misconception and how a learner would detect it.
- [ ] **AI-use boundaries.** What learners may ask a model, which data tier goes to which model, where the approval gate sits, and that a model's suggestion is never approval. If the lab uses an agent, the gate is code before execution.
- [ ] **Validation checkpoints.** At least two points where a learner confirms a model or tool claim with independent evidence before continuing.
- [ ] **Defensive extension.** The detection idea, remediation, and validation step for the main finding, and the telemetry needed to write them.
- [ ] **Reset.** How the lab returns to a known state between learners and sections.
- [ ] **Instructor troubleshooting notes.** The three most likely failures and the move for each, including a learner exceeding scope.

LAB 8 · SAFETY REVIEW · 5:00 TO 5:10

Lab 8 Safety Review

Pairs grouped by platform swap canvases. Answer both questions in writing at the bottom of your partner's canvas, then revise your own from your partner's answers. Save it to the shared folder as `S4_Lab8_<lastname>.md`.

Partner reviewed	

1. Could a learner following this canvas touch anything outside the authorized assets? Name the step and the asset, or state why no step can.

2. Could a learner complete the validation checkpoints by asking a model, without looking at the evidence? Name the checkpoint, or state why none can.

What I Changed After Review

Three Likely Failures and the Move for Each

Failure	Instructor move
A learner exceeds the scope	Stop the learner, preserve the shell history and logs, and debrief the stop condition.

SCORING

Lab 7 (20 Points) and Lab 8 (10 Points)

Lab 7: Authorized Assessment of the Staging Portal

Criterion	Points	Full credit	Score
Scope and authorization	4	Signed read-back restates all seven elements and the approval rule. The six actions are classified with deciding elements. Every capture or recommendation outside the scope is excluded or refused, and reported through the reporting path.	
Raw-output record	3	Every capture is logged with tool, command, target as authorized, time with zone, and hash before any model run. Observed and inferred stay in separate columns.	
Hypotheses and validation	5	Model hypotheses are recorded with model and time. Every service claim is tested with at least two independent pieces of evidence. Evidence that rests on the same observation is counted once. Corrections are recorded.	
Approval and the least invasive finding	3	The four-part request is complete before the test. The least invasive test is requested. Any exposed file is described by name, size, and timestamp only.	
Purple-team translation and briefing	5	The timeline is reconciled on time zone, clock, sensor placement, and false positive. The detection idea has a data source, condition, and false positives. The remediation has an owner. The validation repeats the original observation. Confidence is stated, and the recommendation follows from the evidence.	
		Total of 20	

Lab 8: Redesign a Legacy Lab as Purple Team

Criterion	Points	Full credit	Score
Authorization and stop conditions	2	All seven elements and the approval rule. Stop conditions a student can observe.	
Expected findings and misconception	2	Instructor truth for every target. One planted misconception with a detection path.	
AI-use boundaries and gate	2	Data tiers per model. Gate placement stated. A model suggestion is not approval.	
Validation and defensive extension	2	Two checkpoints a model cannot satisfy alone. Detection, remediation, and validation for the main finding.	
Reset, troubleshooting, and accessibility	2	Reset named. Three failures with moves. An accessibility path that reaches the same performance.	
		Total of 10	

> Save the Lab 7 read-back by 1:45, post the approval request in chat by 2:45, deliver the written finding by 4:25, and save the Lab 8 canvas by 5:10.

5:10 · DEBRIEF

Debrief, Exit Ticket, and Session 5

Debrief Prompts

1. Which raw evidence mattered most?
2. What did the AI infer that the tool did not actually report?
3. Where should an approval gate sit in an agentic workflow?
4. How did the offensive result improve defense?
5. Would a novice understand why the test is legal here and not elsewhere?

The Record Behind Today

Source	What it establishes
Anthropic, GTG-1002 report, November 2025 [13]	An agent ran an estimated 80 to 90 percent of an intrusion campaign. Humans sat at the escalation points, and the agent's claimed results needed validation.
Willison, June 16, 2025 [9]	Private data, untrusted content, and external communication together make an agent exploitable.
OWASP Top 10 for Agentic Applications, December 2025 [11]	ASI01 Agent Goal Hijack and ASI02 Tool Misuse and Exploitation, with mitigations that include human approval for high-impact actions.
Cybench, ICLR 2025 [14]	Unguided agents solved only tasks that took human teams up to 11 minutes. The hardest task took human teams 24 hours and 54 minutes.
Nmap Reference Guide [3]	Version detection matches a service's responses against stored patterns. Most services do not provide all the information it looks for.
NVD and Apache records, CVE-2021-41773 [5, 4]	A path traversal flaw in Apache HTTP Server 2.4.49 only, fixed in 2.4.50 on October 4, 2021, and in the CISA KEV catalog since November 3, 2021.

Bracketed numbers are references in the Session 4 Student Guide.

Exit Ticket

Submit through the form link in chat, or answer here and photograph the page.

1. The planted misconception you will put in your redesigned lab

2. Where the approval gate sits in it

3. Your readiness to run Lab 7 with your own students

□ 1 □ 2 □ 3 □ 4 □ 5 What would move you up one point?

> **Session 5 preview: Agentic AppSec and the 12-Month Roadmap, November 20.** The same student-support portal is back. A developer has an AI-assisted patch for it with passing unit tests, and Northbridge must decide whether to merge it. Bring a code or configuration artifact from your course, your syllabus, and the roadmap facts table from the prework.